PENSE-BÊTE · RECOMMANDATIONS DE SÉCURITÉ

Sécurité sous Debian 13

06-740 PSE 25-27 5-16 Linux - La sécurité sous Debian 13, questions de révision — source : fiche de révision du module (gemma4, 03/11/2026)

À RETENIR

1. La règle de sauvegarde 3 2 1 impose de conserver trois copies des données sur deux supports différents dont une copie externalisée hors site.
2. Le fichier /etc/shadow stocke les empreintes hachées des mots de passe avec l'algorithme yescrypt par défaut depuis Debian 11.
3. Les capabilities Linux permettent d'accorder un privilège précis et limité à un processus au lieu d'utiliser le bit SUID root.

Fondamentaux de la sécurité

Notion	À retenir
Concepts DICP et DICT	DICP : **Disponibilité**, **Intégrité**, **Confidentialité**, **Preuve** ou **Traçabilité**. DICT : extension qui **peut** faire de la **Traçabilité** un critère distinct de la **Preuve**, selon les référentiels.
Stratégie 3 2 1	**3** copies des données, **2** supports différents, **1** copie externalisée hors site.
EBIOS Risk Manager	Méthode **ANSSI** par ateliers (**cadrage**, **sources**, **scénarios stratégiques**, **opérationnels**, **traitement**) aboutissant à un **plan d'action priorisé** pour la **PSSI**.

Gestion des accès et authentification

Notion	À retenir
Hachage yescrypt	Stocké dans `/etc/shadow` (distinct de `/etc/passwd`). Préfixe `$y$`. Remplace **SHA-512** (préfixe `$6$`) depuis **Debian 11**. Utilise un **sel aléatoire**.
Modules PAM	Type `required` : doit réussir, mais l'évaluation continue. Type `requisite` : doit réussir, sinon l'échec **interrompt immédiatement** le processus.
Protocole RADIUS	Concept **AAA** : **Authentication** (identité), **Authorization** (droits/privilèges) et **Accounting** (journalisation). Usage : accès Wi-Fi via **802.1X** ou **WPA2-Enterprise**.
Recommandations	Déconseiller le **renouvellement forcé** fréquent. Privilégier l'**authentification par clé SSH** (plus robuste, clé privée insensible au brute force) plutôt que les mots de passe.

Protection du système et durcissement

Notion	À retenir
SUID root vs Capabilities	Le **SUID root** donne l'intégralité des privilèges sans granularité ; les **capabilities Linux** accordent un privilège précis (ex: `cap_net_bind_service` pour port **< 1024**) respectant le **moindre privilège**.
Contrôle d'accès et AppArmor	Le **contrôle d'accès obligatoire** (**classe B1** de l'**Orange Book**) impose une politique indépendante de la volonté du propriétaire, contrairement au modèle **discrétionnaire**.
chroot vs Namespaces	Le **chroot** change le répertoire racine mais offre des garanties limitées (partage des **UID**, risque de **chroot breakout**) ; les **namespaces** offrent une **isolation réelle**.
Montages sécurisés	L'option `noexec` sur `/tmp` empêche l'exécution de binaires, mais peut faire échouer des **installeurs** ou **scripts tiers** ; nécessite une **validation en environnement de test**.

Sécurité réseau et surveillance

Notion	À retenir
Filtrage trafic	Utiliser des règles `nftables` avec un `drop` par défaut sur l'**input** et `fail2ban` pour bloquer les accès malveillants.
Journaux et antivirus	`journald` / `journalctl` pour les traces ; **ClamAV** (paquets `clamav`, `clamav-daemon`) pour l'antivirus (commandes ci-dessous).

Commandes de surveillance et antivirus

Commande	À quoi ça sert
`journalctl -u [service]`	cibler spécifiquement un service
`journalctl --since today`	limiter l'affichage aux événements depuis minuit
`journalctl -b`	limiter l'affichage au dernier démarrage
`freshclam`	effectuer la mise à jour des signatures de virus
`clamscan`	lancer l'analyse du système
`clamdscan`	lancer l'analyse du système en mode démon

Synthèse Cryptographie et Défense

Notion	À retenir
Algorithmes RGS	Proscrire **DES**, **RC4**, **MD5**, **SHA-1**. Utiliser **AES-256** et **SHA256** (ou supérieur).
Défense en profondeur	La défaillance d'une couche ne doit pas compromettre le système. Utiliser **AppArmor** ou les **capabilities** (vs **SUID root**).
Évolution référentiels	L'**Orange Book** (**TCSEC**) est obsolète, remplacé par les **Critères Communs**. La classe **B1** introduit le **MAC** (contrôle d'accès obligatoire).

Modèles de contrôle d'accès (Classe B1)

	Modèle discrétionnaire	Contrôle d'accès obligatoire (MAC)
Principe	L'utilisateur décide seul des droits sur ses ressources	Politique imposée via des étiquettes de sensibilité
Indépendance	Dépend de la volonté du propriétaire du fichier	Indépendant de la volonté du propriétaire du fichier

Pièges et confusions

- ⚠ Confondre le fichier /etc/passwd avec /etc/shadow qui contient les empreintes hachées.
- ⚠ Confondre les modules PAM required et requisite.
- ⚠ Utiliser le bit SUID root au lieu des capabilities Linux pour accorder des privilèges.
- ⚠ Croire que le mécanisme chroot permet d'isoler réellement les processus, le réseau ou les utilisateurs.
- ⚠ Appliquer un renforcement excessif de la complexité des mots de passe.

Sigles et définitions

DICP — Disponibilité, Intégrité, Confidentialité et Preuve (ou Traçabilité)

AAA — Authentication, Authorization, Accounting (serveur RADIUS)

EBIOS Risk Manager — Méthode d'analyse de risque de l'ANSSI aboutissant à un plan d'action alimentant la PSSI.

ClamAV — Solution antivirus utilisant freshclam pour les signatures et clamscan pour l'analyse.

DAC — Contrôle d'accès discrétionnaire où le propriétaire décide seul des droits sur un fichier.

Orange Book — Référentiel TCSEC ; sa classe B1 introduit le contrôle d'accès obligatoire

Auto-test

1. Quel algorithme est utilisé par défaut pour le hachage dans /etc/shadow depuis Debian 11 ?
2. Quelle commande permet d'effectuer la mise à jour des signatures de virus avec ClamAV ?
3. Quel type de module PAM interrompt immédiatement le processus en cas d'échec ?
4. Quelle option de journalctl permet de limiter l'affichage au dernier démarrage ?
5. Quels algorithmes de chiffrement ou de hachage le RGS de l'ANSSI recommande-t-il ?

Réponses : **1.** yescrypt · **2.** freshclam · **3.** requisite · **4.** -b · **5.** AES-256 (chiffrement) et SHA256 (hachage)

À compléter par la fiche, le podcast et le quiz du module. Rédigé à partir de la fiche de révision ; seuils et chiffres à la date de la source.